

통합관리기관 지정요건(제8조제2항 관련)

구 분			세 부 조 치 사 항
1. 기반 시설	1.1 전산운영	1.1.1. 데이터센터 공간	서버, 스토리지 등의 정보통신장비와 함께 소방설비, CCTV 등을 구비하여 물리적 안정성이 보장되어야 하며, 외부와 공간이 분리되어 접근 통제가 가능해야 한다.
		1.1.2. 전력공급시설	정전, 전압 변동 등의 상황이 발생하더라도 통합관리기관에 안정적인 전력을 공급하기 위한 수·배전, 무정전전원장치 등을 구비해야 한다.
		1.1.3. 공조시설	데이터센터 내부를 일정한 온도 및 습도로 유지하기 위한 시설 또는 외기 냉방시설 등을 구비해야 한다.
		1.1.4. 비상발전시설	장시간 정전이 발생할 경우 통합관리기관 전체부하를 감당할 수 있도록 비상발전기 등 자체 전력공급 능력을 구비해야 한다.
	1.2 에너지 효율	1.2.1 고효율기기	신규 또는 교체·개체 수요 발생 시 특별한 사유가 없는 한 「고효율에너지기자재 보급촉진에 관한 규정」(산업통상자원부고시)에 따른 고효율에너지기자재 인증제품, 「효율관리기자재 운용규정」(산업통상자원부고시)에 따른 에너지소비효율 1등급 제품 또는 「대기전력저감프로그램 운용규정」(산업통상자원부고시)에 따른 에너지절약마크가 표시된 제품을 우선 적용해야 한다. 다만, 고효율에너지기자재 인증제품 또는 에너지소비효율 1등급 제품이 없는 경우에는 차상위 에너지효율등급 제품을 적용할 수 있다.
		1.2.2. 에너지효율 관리	데이터센터를 신축하거나 별동으로 증축하는 경우 에너지 효율을 최대화하고 환경에 미치는 영향을 최소화하여 운영되도록 설계해야 하며, 「에너지이용 합리화법」 제2조에 따른 에너지관리시스템을 구축·운영해야 한다.
			태양광 등 신·재생에너지 설비 도입을 통해 데이터센터의 에너지자립률 향상을 위해 노력해야 한다. 한국산업표준(KS) X ISO/IEC 30134-2에 따른 전력사용효율지수(PUE*)를 설정하여 측정·관리하고, 데이터센터의 지속적인 에너지효율 개선을 위해 노력해야 한다. * PUE(Power Usage Effectiveness, 전력사용효율지수)
2. 정보 보호 정책 및 조직	2.1. 정보보호 정책	2.1.1. 정보보호 정책 수립	정보보호 정책을 문서화하고, 정보보호 최고책임자의 승인 후 정책에 영향을 받는 모든 업무 관련자에게 제공해야 한다.
		2.1.2. 정보보호 정책 검토 및 변경	정보보호 정책의 타당성 및 효과를 연 1회 이상 검토하고, 관련 법규 변경 및 내·외부 보안사고 발생 등의 중대한 사유가 발생할 경우에는 추가로 검토하고 변경해야 한다.
		2.1.3. 정보보호 정책문서 관리	정보보호 정책 및 정책 시행문서의 이력관리 절차를 수립·시행해야 한다.
	2.2.	2.2.1.	정보보호 활동을 계획·실행·검토하는 정보보호 전담조직을

구 분			세 부 조 치 사 항
	정보보호 조직	조직 구성	구성하고 정보보호 최고책임자를 임명해야 한다.
		2.2.2. 역할 및 책임 부여	정보자산과 보안에 관련된 모든 업무 관련자의 정보보호 역할과 책임을 명확하게 정의해야 한다.
		2.2.3. 보안에 관한 책무	통합관리기관과 이용기관의 보안에 관한 책임범위는 업무별 특성 등을 고려하여 양 기관이 협약으로 정한 책임과 역할에 따라 정해지며, 정해진 소관 업무범위에 따라 침해사고의 예방·대응·복구활동을 수행해야 한다.
3. 인적 보안	3.1. 내부인력 보안	3.1.1. 주요 직무자 지정 및 감독	정보시스템 운영·개발 및 정보보호 등에 관련된 부서장의 경우 주요 직무자로 지정하여 관리하고, 직무 지정 범위는 최소화해야 한다.
		3.1.2. 직무 분리	권한 오남용 등 내부 부서장의 고의적인 행위로 발생할 수 있는 잠재적인 위협을 줄이기 위하여 직무분리 기준을 수립하고 적용해야 한다.
		3.1.3. 비밀유지서약서	정보보호와 개인정보보호 등을 위해 필요한 사항을 비밀유지서약서에 정의하고 주기적으로 갱신해야 한다.
		3.1.4. 퇴직 및 직무변경	직원의 퇴직 또는 직무 변경에 관한 책임을 명시적으로 정의하고 수행해야 한다. 또한 이에 대한 접근권한도 제거해야 한다.
	3.2. 외부인력 보안	3.2.1. 외부인력 계약	외부인력(외부유지보수직원, 외부용역자 포함)에 의한 정보자산 접근 등과 관련된 보안요구사항을 계약에 반영해야 한다.
		3.2.2. 외부인력 보안 이행 관리	계약서에 명시한 보안요구사항 준수 여부를 주기적으로 점검하고 위반사항이나 침해사고 발생 시 적절한 조치를 수행해야 한다.
		3.2.3. 계약 만료 시 보안	외부인력과의 계약 만료 시 자산 반납, 접근권한의 회수, 중요정보 파기, 업무 수행 시 알게 된 정보에 대한 비밀 유지서약 등을 확인해야 한다.
	3.3. 정보보호 교육	3.3.1. 교육 프로그램 수립	모든 직원 및 외부 업무 관련자를 포함하여 연간 정보보호 교육 프로그램을 수립해야 한다.
		3.3.2. 교육 시행	모든 직원 및 외부 업무 관련자를 대상으로 연 1회 이상 정보보호 교육을 시행하고 정보보호 정책 및 절차의 중대한 변경, 내·외부 보안사고 발생, 관련 법규 변경 등의 사유가 발생하면 추가 교육을 실시해야 한다.
		3.3.3. 평가 및 개선	정보보호 교육 시행에 대한 기록을 남기고 결과를 평가하여 개선해야 한다.
4. 자산 관리	4.1. 자산 식별 및 분류	4.1.1. 자산 식별	정보자산(시설, 장비, 소프트웨어 등)에 대한 자산분류기준 수립하고 식별된 자산의 목록을 작성하여 관리해야 한다.
		4.1.2. 자산별 책임할당	식별된 자산마다 책임자 및 관리자를 지정하여 책임소재를 명확히 해야 한다.
		4.1.3. 보안등급 및 취급	기밀성, 무결성, 가용성, 법적요구사항 등을 고려하여 자산의 보안등급을 부여하고, 보안등급별 취급 절차에 따라

구 분			세 부 조 치 사 항
			관리해야 한다.
	4.2. 자산 변경관리	4.2.1. 변경관리	정보자산(시설, 장비, 소프트웨어 등)의 변경이 필요한 경우 보안 영향 평가를 통해 변경 사항을 관리해야 한다. 또한 이용자에게 큰 영향을 주는 변경에 대해서는 사전에 공지를 해야 한다.
		4.2.2. 변경 탐지 및 모니터링	정보자산(시설, 장비, 소프트웨어 등)의 변경을 지속적으로 모니터링하여 허가받지 않은 변경을 탐지하고 최신의 변경 이력을 유지해야 한다.
		4.2.3. 변경 후 작업검증	정보자산(시설, 장비, 소프트웨어 등)의 변경 후에는 보안성 및 호환성 등에 대한 작업검증을 수행해야 한다.
	4.3. 위험관리	4.3.1. 위험관리계획 수립	관리적, 기술적, 물리적, 법적 분야 등 정보보호 전 영역에 대한 위험식별 및 평가가 가능하도록 위험관리 방법과 계획을 사전에 수립해야 한다.
		4.3.2. 취약점 점검	취약점 점검 정책에 따라 주기적으로 기술적 취약점(예 : 유·무선 네트워크, 운영체제 및 인프라, 응용 프로그램 취약점 등)을 점검하고 보완해야 한다.
		4.3.3. 위험분석 및 평가	위험관리 방법 및 계획에 따라 정보보호 전 영역에 대한 위험 식별 및 평가를 연 1회 이상 수행하고 그 결과에 따라 수용 가능한 위험수준을 설정하여 관리해야 한다.
		4.3.4. 위험처리	법규 및 계약관련 요구사항과 위험수용 수준을 고려하여 위험평가 결과에 따라 통제할 수 있는 방법을 선택하여 처리해야 한다.
5. 침해 사고 관리	5.1. 침해사고 대응 절차 및 체계	5.1.1. 침해사고 대응 절차 수립	침해사고에 대한 효율적이고 효과적인 대응을 위해 신고절차, 유출 금지 대상, 사고 처리 절차 등을 담은 침해사고 대응절차를 마련해야 한다. 침해사고 대응절차는 통합관리기관과 이용기관의 책임과 절차가 포함되어야 한다.
		5.1.2. 침해사고 대응 체계 구축	침해사고 정보를 수집·분석·대응할 수 있는 보안관제 시스템 및 조직을 구성·운영하고, 침해사고 유형 및 중요도에 따라 보고 및 협력체계를 구축해야 한다.
		5.1.3. 침해사고 대응 훈련 및 점검	침해사고 대응과 관련된 역할 및 책임이 있는 담당자를 훈련시켜야 하고, 주기적으로 침해사고 대응 능력을 점검해야 한다.
	5.2. 침해사고 대응	5.2.1. 침해사고 보고	침해사고 발생 시 침해사고 대응절차에 따라 이용기관에게 발생 내용, 원인, 조치 현황 등을 신속하게 알려야 한다.
		5.2.2. 침해사고 처리 및 복구	침해사고 발생 시 침해사고 대응절차에 따라 처리와 복구를 신속하게 수행해야 한다
	5.3. 사후관리	5.3.1. 침해사고 분석 및 공유	침해사고가 처리 및 종결된 후 발생 원인을 분석하고 그 결과를 이용기관에게 알려야 한다. 또한 유사한 침해사고에 대한 신속한 처리를 위해 침해사고 관련 정보 및 발견된 취약점을 행정안전부, 국가정보원 등 사이버 보안 유관기관과

구 분			세 부 조 치 사 항
			공유해야 한다.
		5.3.2. 재발방지	침해사고 관련 정보를 활용하여 유사한 침해사고가 반복되지 않도록 침해사고 재발방지 대책을 수립하고, 필요한 경우 침해사고 대응 체계도 변경해야 한다.
6. 서비스연 속성 관리	6.1. 장애대응	6.1.1. 장애 대응절차 수립	업무 연속성을 보장하기 위해 백업, 복구 등을 포함하는 장애 대응 절차를 마련해야 한다.
		6.1.2. 장애 보고	서비스 중단이나 피해가 발생한 경우, 장애 대응절차에 따라 이용기관에게 발생 내용, 원인, 조치 현황 등을 신속하게 알려야 한다.
		6.1.3. 장애 처리 및 복구	서비스 중단이나 피해가 발생한 경우, 서비스 수준 협약(SLA)에 명시된 시간 내에 장애대응절차에 따라 해당 서비스의 장애를 처리하고 복구시켜야 한다.
		6.1.4. 재발방지	장애 관련 정보를 활용하여 유사한 서비스 중단이 반복되지 않도록 장애 재발방지 대책을 수립하고, 필요한 경우 장애 대응 절차도 변경해야 한다.
	6.2. 서비스 가용성	6.2.1.	서버, 스토리지, 네트워크 장비, 통신 케이블, 접속 회선 등의 장애로 서비스가 중단되지 않도록 이중화하고, 장애 및 재난재해 발생 시 신속하게 복구를 수행하도록 백업체계를 구축해야 한다.
		6.2.1.	이중화 및 백업
7. 준거 성	7.1. 법 및 정책 준수	7.1.1. 법적요구사항 준수	정보보호 관련 법적 요구사항을 식별하고 준수해야 한다.
		7.1.2. 정보보호 정책 준수	정보보호 정책 및 서비스 수준 협약에 포함된 보안 요구사항을 식별하고 준수하며 이용자가 요구하는 경우 관련 증거를 제공해야 한다.
		7.1.3. 감사기록 및 모니터링	보안감사 증적(로그)은 식별할 수 있는 형태로 기록 및 모니터링 되어야 하고 비인가된 접근 및 변조로부터 보호되어야 한다.
8. 물리 적 보안	8.1. 물리적 보호구역	8.1.1. 물리적 보호구역 지정	중요 정보 및 정보처리시설을 보호하기 위한 물리적 보안 구역(예 : 주요 정보처리 설비 및 시스템 구역, 사무실, 외부인 접견실 등)을 지정하고, 각 보안 구역에 대한 보안 대책을 마련해야 한다.
		8.1.2. 물리적 출입통제	물리적 보안 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 시설(예 : 경비원, 출입 통제 시스템 등)을 갖추어야 하고, 출입 및 접근 이력을 주기적으로 검토해야 한다.
		8.1.3. 물리적 보호구역 내 작업	유지보수 등 주요 정보처리 설비 및 시스템이 위치한 보호구역 내에서의 작업 절차를 수립하고 작업에 대한 기록을 주기적으로 검토해야 한다.
		8.1.4. 사무실 및 설비 공간 보호	사무실 및 설비 공간에 대한 물리적인 보호방안을 수립하고 적용해야 한다.
		8.1.5.	공공장소 및 운송·하역을 위한 구역은 내부

구 분			세 부 조 치 사 항
		운송·하역구역 보호	정보처리시설로부터 분리 및 통제해야 한다.
		8.1.6. 모바일 기기 반출·입	노트북 등 모바일 기기 미승인 반출입을 통한 중요정보 유출, 내부망 악성코드 감염 등의 보안사고 예방을 위하여 보호구역 내 직원 및 외부인력 모바일 기기 반출입 통제절차를 수립하고 기록·관리해야 한다
	8.2. 정보처리 시설 및 장비보호	8.2.1. 정보처리시설의 배치	물리적 및 환경적 위험으로부터 잠재적 손상을 최소화하고 비인가 된 접근 가능성을 최소화하기 위하여, 정보처리시설 내 장비의 위치를 파악하고 배치해야 한다.
		8.2.2. 보호설비	각 보안 구역의 중요도 및 특성에 따라 화재, 누수, 전력 이상 등 자연재해나 인재에 대비하여 화재 감지기, 소화 설비, 누수 감지기, 항온 항습기, 비상발전기, 무정전 전원 장치(UPS), 이중 전원선 등의 설비를 갖추어야 한다.
		8.2.3. 케이블 보호	데이터를 송수신하는 통신케이블이나 전력을 공급하는 전력 케이블은 손상이나 도청으로부터 보호해야 한다.
		8.2.4. 시설 및 장비 유지보수	정보처리시설은 가용성과 무결성을 지속적으로 보장할 수 있도록 유지보수해야 한다.
		8.2.5. 장비 반출·입	장비의 미승인 반출·입을 통한 중요 정보 유출, 악성코드 감염 등의 침해사고 예방을 위하여, 보안 구역 내 직원 및 외부 업무 관련자에 의한 장비 반출·입 절차를 수립하고, 기록 및 관리해야 한다.
		8.2.6. 장비 폐기 및 재사용	정보처리시설 내의 저장 매체를 포함하여 모든 장비를 파악하고, 민감한 데이터가 저장된 장비를 폐기하는 경우 복구 불가능하도록 해야 한다. 또한 재사용하는 경우에도 복구 불가능 상태에서 재사용해야 한다.
9. 접근 통제	9.1. 접근통제 정책	9.1.1. 접근통제 정책 수립	비인가자의 접근을 통제할 수 있도록 접근통제 영역 및 범위, 접근통제 규칙, 방법 등을 포함하여 접근통제 정책을 수립해야 한다.
		9.1.2. 접근기록 관리	접근기록 대상을 정의하고 서비스 통제, 관리, 사고 발생 책임 추적성 등을 보장할 수 있는 형태로 기록되고 유지해야 한다.
	9.2. 접근 권한 관리	9.2.1. 사용자 등록 및 권한부여	시스템 및 중요정보에 대한 접근을 통제하기 위하여 공식적인 사용자 등록 및 해지 절차를 수립하고 업무 필요성에 따라 사용자 접근권한을 최소한으로 부여해야 한다.
		9.2.2. 관리자 및 특수 권한관리	시스템 및 중요정보 관리 및 특수 목적을 위해 부여한 계정 및 권한을 식별하고 별도 통제해야 한다.
		9.2.3. 접근권한 검토	시스템 및 중요정보에 대한 접근을 관리하기 위하여 접근권한 부여, 이용(장기간 미사용), 변경(퇴직 및 휴직, 직무변경, 부서변경)의 적정성 여부를 정기적으로 점검해야 한다.
	9.3.	9.3.1.	시스템에서 사용자를 유일하게 구분할 수 있는 식별자를

구 분			세 부 조 치 사 항
	사용자 식별 및 인증	사용자 식별	할당하고 추측 가능한 식별자 사용을 제한해야 한다. 동일한 식별자를 공유하여 사용하는 경우 그 사유와 타당성을 검토하고 책임자의 승인을 받아야 한다.
		9.3.2. 사용자 인증	시스템에 대한 접근은 사용자 인증, 로그인 횟수 제한, 불법 로그인 시도 경고 등 안전한 사용자 인증 절차에 의해 통제해야 한다.
		9.3.3. 패스워드 관리	법적 요구사항, 외부 위협요인 등을 고려하여 패스워드 복잡도 기준, 초기 패스워드 변경, 변경주기 등 패스워드 관리절차를 수립·이행해야 한다. 특히 관리자 패스워드는 별도 보호대책을 수립하여 관리해야 한다.
10. 네트워크 보안	10.1. 네트워크 보안	10.1.1. 보안 정책 수립	서비스와 관련된 내·외부 네트워크에 대해 보안 정책과 절차를 수립해야 한다.
		10.1.2. 네트워크 모니터링 및 통제	DDoS, 비인가 접속 등으로 인한 서비스 중단 및 중요 정보 유출 등을 막기 위해 네트워크를 모니터링하고 통제해야 한다.
		10.1.3. 네트워크 정보보호	서비스와 관련된 내·외부 네트워크를 보호하기 위하여 정보보호시스템(방화벽, IPS, IDS, VPN 등)을 운영해야 한다.
		10.1.4. 네트워크 암호화	시스템에서 중요 정보가 이동하는 구간에 대해서는 암호화된 통신채널을 사용해야 한다.
		10.1.5. 네트워크 분리	시스템관리 영역과 서비스 영역의 네트워크 접근은 물리적 또는 논리적으로 분리해야 한다. 행정기관의 경우 국가정보원의 행정업무망과 인터넷망의 분리 정책을 유지해야 한다.
		10.1.6. 무선 접근통제	시스템은 무선망과 분리하고 무선접속에 대한 접근을 통제해야 한다. 무선접속을 사용하는 경우 그 사유와 타당성을 검토하고 책임자의 승인을 받아야 한다
11. 가상화 보안	11.1. 가상화 인프라	11.1.1. 가상자원 관리	가상화기술을 적용한 경우 가상자원(가상 머신, 가상 스토리지, 가상 소프트웨어 등)의 생성, 변경, 회수 등에 대한 관리 방안을 수립해야 한다.
		11.1.2. 가상자원 모니터링	가상화 기술을 적용한 경우 가상자원에 대한 무결성을 보장하기 위한 보호조치 및 가상자원의 변경(수정, 이동, 삭제, 복사)에 대해 모니터링 해야 한다. 또한, 가상자원에 손상이 발생한 경우 이를 이용기관에게 알려주어야 한다.
		11.1.3. 하이퍼바이저 보안	가상화 기술을 적용한 경우 가상자원을 관리하는 하이퍼바이저의 기능 및 인터페이스에 대한 접근 통제 방안을 마련해야 한다. 또한 하이퍼바이저에 대한 소프트웨어 업데이트 및 보안패치를 최신으로 유지해야 한다.
		11.1.4. 공개서버 보안	가상화 기술을 적용한 경우 가상자원을 제공하기 위한 웹사이트와 가상소프트웨어(앱, 응용프로그램)를 배포하기 위한 공개서버에 대한 물리적, 기술적 보호대책을 수립해야

구 분			세 부 조 치 사 항
12. 데이 터 보 호 및 암 호 화			한다.
		11.1.5. 상호 운용성 및 이식성	가상화기술을 적용한 경우 표준화된 가상화 포맷, 이식성이 높은 가상화 플랫폼, 공개 API 등을 이용하여 서비스 간의 상호 운용성 및 이식성을 높여야 한다.
	12.1 보안인증	12.1.1 CC인증	서비스 구축을 위해 도입되는 서버·PC 가상화 솔루션 및 정보보호 제품 중에 CC인증이 필수적인 제품군은 국내·외 CC인증을 받은 제품을 사용해야 한다.
		12.1.2 검증필 암호화	정보시스템을 통해 생성된 중요자료를 암호화하는 수단을 제공하는 경우에는 검증필 국가표준암호화 기술을 제공해야 한다.
	12.2 매체 보안	12.2.1. 저장매체 관리	중요정보를 담고 있는 하드디스크, 스토리지 등의 저장매체 폐기 및 재사용 절차를 수립하고 매체에 기록된 중요정보는 복구 불가능하도록 완전히 삭제해야 한다.
		12.2.2. 이동매체 관리	중요정보 유출을 예방하기 위해 외장하드, USB, CD 등 이동매체 취급, 보관, 폐기, 재사용에 대한 절차를 수립해야 한다. 또한 매체를 통한 악성코드 감염 방지 대책을 마련해야 한다.
	12.3. 암호화	12.3.1. 암호 정책 수립	저장 또는 전송 중인 데이터를 보호하기 위해 암호화 대상, 암호 강도(복잡도), 키관리, 암호 사용에 대한 정책을 마련해야 한다. 또한 정책에는 개인정보 저장 및 전송 시 암호화 적용 등 암호화 관련 법적 요구사항을 반드시 반영해야 한다.
		12.3.2. 암호키 관리	암호키 생성, 이용, 보관, 배포, 파기에 관한 안전한 절차를 수립하고, 암호키는 별도의 안전한 장소에 보관해야 한다.